Agent Mandate Template

Version 0.1 · November 2026 · Rui Soares · Licence: CC BY-SA 4.0

An AI agent holds a mandate as soon as it acts without a human approving each action. From that moment, the question is no longer whether it is used well. The question is whether it was allowed to do what it did, and who said so.

This template sets out that authorisation as thirteen fields in three groups:

- **Authority:** who grants the mandate, to whom, and what it covers.
- **Control:** how the agent is kept within bounds while it runs.
- **Lifecycle:** how the mandate stays valid over time.

The worked example comes first and the blank template after it. Fill in your own version only once you have seen a finished one.

> **Status of standards (November 2026).** Protocols are starting to standardise the *token*: signed payment mandates (Google AP2), an IETF individual draft on verifiable agent mandates, and NIST NCCoE work on agent identity. None of them yet standardises the *governance*: who sponsors, who owns, and what triggers revalidation. This template covers that part.

How to use it

1. Write one mandate per agent instance, not one per product or vendor.
2. Have the **sponsor** sign it and the **owner** keep it.
3. Enforce every limit outside the prompt: in identity, permissions, policy engines or approval gates. A limit written only in a system prompt is not a boundary.
4. Store the mandate with your asset inventory, and review it at expiry or whenever a revalidation trigger fires.

Worked example: a Tier-1 SOC triage agent

Context (illustrative). A mid-sized logistics company runs a small security operations centre. Alert volume outgrew the analysts, so an agent now triages endpoint and SIEM alerts overnight. For a narrow class of cases, it may isolate a workstation from the network.

Field	Example
Sponsor	Head of Security Operations. Under the incident response procedure, this role may isolate endpoints and disable accounts during an incident.
Holder	The agent instance `soc-triage-01`, with its own workload identity. It never runs under a human analyst's account.
Purpose	Triage endpoint and SIEM alerts, enrich and classify them, and contain low-risk workstation compromises. **Not for:** deleting data, changing firewall rules, touching servers or OT systems, contacting anyone outside the SOC, or closing incidents.
Scope	Read SIEM and EDR alerts and threat-intelligence feeds. Write to the ticketing system. Run the EDR *isolate* action on user workstations only.
Limits	At most 3 isolations an hour and 10 a day. Never isolates a device tagged as executive, critical-function or shared-terminal.
Delegation	May call one enrichment sub-agent with read-only access to threat intelligence and the SIEM. It may not delegate isolation. Maximum depth: 1.
Reversibility	Isolation can be undone from the EDR console, but it still stops someone's work, so "reversible" does not mean "harmless". Irreversible actions such as data deletion are out of scope altogether.
Escalation	A human decides when: severity is high or critical; a server or domain controller is involved; the hourly limit is reached (a possible mass event, or the agent in a loop); intelligence sources conflict; or **the alert involves the agent's own identity or tooling.** An agent never investigates itself.
Evidence	For every alert: inputs, classification, the reasoning given for it, the action taken and any sub-agent calls. Kept under the log retention policy and readable by the SOC lead and auditors.
Owner	SOC lead. Deputy: the senior analyst on the rota.
Expiry	90 days for the pilot. After that, six months per renewal, each renewal following a review of false positives and false negatives.
Revocation	The Head of Security Operations or the CISO. Withdrawing the EDR action permission takes effect within 15 minutes. Pending actions move to the human queue. **Isolations already made stay in place until a human reviews them.** Revoking the agent does not undo its work automatically.
Revalidation trigger	A model or prompt change, a new EDR or SIEM integration, a new alert source, any change to the incident response procedure (the sponsor's authority comes from it), or any incident the agent caused or missed.

Sponsor check: passed. The sponsor may isolate any endpoint during an incident. The agent may isolate only workstations, only within limits, and never the tagged ones. Its mandate sits inside the sponsor's authority.

Blank template

Field	Your agent
Sponsor	
Holder	
Purpose (including what it is *not* for)	
Scope	
Limits (per action *and* cumulative)	
Delegation (allowed? how narrow? how deep?)	
Reversibility	
Escalation	
Evidence	
Owner (and deputy)	
Expiry	
Revocation (who, how fast, and what happens to work in progress)	
Revalidation trigger	

Sponsor check: does any part of this mandate exceed the sponsor's own authority? ☐ No ☐ Yes → stop.

Field guide

The ISO/IEC 27001:2022 Annex A column is an indicative mapping to help ISMS owners and auditors. It is not certification guidance.

Group	Field	Question it answers	Derived control	ISO/IEC 27001:2022 Annex A
Authority	Sponsor	Whose authority is delegated?	Authority check: the mandate never exceeds the sponsor's authority	5.2 Roles and responsibilities; 5.3 Segregation of duties
Authority	Holder	Which agent holds it?	Unique agent identity; the mandate cannot be transferred	5.16 Identity management
Authority	Purpose	What is it for, and not for?	Acceptable-use rule for the agent	5.10 Acceptable use of information and other associated assets
Authority	Scope	Which systems, data and actions?	Least-privilege access	5.15 Access control; 8.3 Information access restriction
Authority	Limits	How much, how often, by when?	Monitoring thresholds	8.16 Monitoring activities
Authority	Delegation	May it pass authority on?	Sub-delegation register, narrowing only	5.18 Access rights; 8.2 Privileged access rights
Control	Reversibility	What can be undone?	Human approval for irreversible actions	5.3 Segregation of duties; 8.2 Privileged access rights
Control	Escalation	When must it stop and ask?	Event triage and incident trigger	5.25 Assessment and decision on information security events
Control	Evidence	What must it record, and for whom?	Audit log	8.15 Logging
Lifecycle	Owner	Who answers for it while it runs?	Named asset owner with a deputy	5.9 Inventory of information and other associated assets
Lifecycle	Expiry	When does it lapse?	Access review at expiry	5.18 Access rights

Lifecycle	Revocation	Who can withdraw it, and how fast?	Revocation and rollback procedure	5.18 Access rights; 5.26 Response to information security incidents
Lifecycle	Revalidation trigger	What change reopens it?	Change request on a model, prompt or tool change	8.32 Change management

Before an agent goes live

1. **List the agents that already hold a mandate.** Anything that acts without per-action approval counts.
2. **Name the sponsor and the owner of each.** If you cannot, that is your first finding.
3. **Write down what each one cannot undo,** and put a human there.
4. **Give every mandate an expiry date,** including the ones that work well.
5. **Treat the next model swap as a change,** and send the mandate back for approval.

Related work

- IETF individual draft draft-hulea-wimse-agent-mandate: verifiable mandates with proof of the delegator's authority. Not adopted by the IETF.
- NIST NCCoE: Software and AI Agent Identity and Authorization
- IMDA Singapore: Model AI Governance Framework for Agentic AI (January 2026)
- Mavračić, *Policy Cards*: machine-readable runtime governance for agents
- TRACE Agent Mandates addendum, the technical counterpart (sub-tokens as W3C Verifiable Credentials). *Disclosure: TRACE is maintained by the author of this template.*

Licensed under CC BY-SA 4.0. Use it, adapt it, share it, and keep the licence.